Clase 312 — Retención, destrucción segura de datos y DLP

> Parte: **17 — Profundización para certificaciones** · Fuente: *NIST SP 800-88 Rev. 1 — Guidelines for Media Sanitization* ⏱️ Duración estimada: **90 min** · Nivel: **Intermedio**

🎯 Objetivo

Aprender a gobernar el **final del ciclo de vida** del dato: definir cuánto tiempo se conserva la información (retención), cómo se elimina de forma verificable (sanitización según NIST SP 800-88) y cómo se evita su fuga durante el uso mediante **DLP** (Data Loss Prevention). La clase conecta la clasificación de la 311 con controles defensivos concretos que exigen CISSP (Asset Security) y CompTIA Security+.

📚 Resultados de aprendizaje

Al finalizar, el alumno podrá:

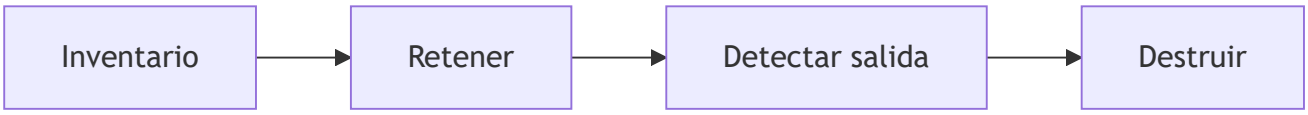
1. **Redactar** un cronograma de retención alineado a requisitos legales y de negocio.
2. **Seleccionar** el método de sanitización correcto (Clear/Purge/Destroy) según medio e impacto.
3. **Diferenciar** borrado lógico, formateo, sobrescritura, criptoborrado y destrucción física.
4. **Diseñar** un flujo de DLP en los tres estados del dato (reposo, tránsito, uso/endpoint).
5. **Producir** un certificado de destrucción con evidencia auditable.
6. **Evitar** los fallos típicos: datos remanentes, SSD mal borrados, retención indefinida.

🗺️ Temas

#	Tema	Por qué importa
1	Políticas de retención	Guardar de más o de menos genera riesgo legal
2	Data remanence (remanencia)	El dato "borrado" a menudo sigue recuperable
3	Modelo Clear / Purge / Destroy	Núcleo de NIST SP 800-88
4	Sanitización por tipo de medio	HDD, SSD, flash y cinta se tratan distinto
5	Criptoborrado (crypto-erase)	Método rápido para medios cifrados y nube
6	DLP: descubrimiento y prevención	Detiene la exfiltración antes de que ocurra
7	Certificados y cadena de custodia	Prueba el cumplimiento ante auditoría
8	Retención en la nube y backups	Los datos sobreviven en réplicas y snapshots

🧠 Modelo mental y caso de decisión

Retención equilibra obligación, necesidad y minimización; DLP observa canales pero no comprende por sí solo propósito.



Caso razonado. Un backup impide cumplir eliminación inmediata; se documenta expiración y acceso restringido en vez de prometer borrado inexistente.

📓 Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

✅ Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

📖 Definiciones y características

- **Retención de datos:** período durante el cual la organización conserva un tipo de dato, fijado por ley, contrato o necesidad de negocio. Característica: define también la **eliminación obligatoria** al vencer el plazo.
- **Data remanence:** información residual que persiste tras un borrado aparente. Es la razón por la que "vaciar la papelera" o formatear no equivale a sanitizar.
- **Clear (limpiar):** técnicas lógicas (sobrescritura, reset) que impiden la recuperación con herramientas estándar. Adecuado para reutilización interna, impacto bajo.
- **Purge (purgar):** técnicas que resisten recuperación de laboratorio: desmagnetización (degaussing), Secure Erase de firmware, criptoborrado. Para medios que salen del control.
- **Destroy (destruir):** desintegración, trituración, incineración o pulverización física. El medio queda inutilizable; el nivel más alto, para datos de alto impacto.
- **Crypto-erase:** borrado de la clave de cifrado que hace ilegible el dato cifrado subyacente. Característica: casi instantáneo, ideal para SSD/nube con cifrado nativo.
- **DLP (Data Loss Prevention):** conjunto de controles que descubren, monitorizan y bloquean el movimiento no autorizado de datos sensibles. Actúa en red, endpoint y almacenamiento.

🧰 Herramientas y preparación

- **NIST SP 800-88 Rev. 1** y su Apéndice A (tabla de sanitización por medio) como referencia guía.

- Utilidades de sanitización (solo sobre medios propios de prueba): `hdparm --security-erase` (ATA Secure Erase en Linux), `blkdiscard` (TRIM en SSD), `nvme format` (NVMe), la utilidad de desmagnetización del fabricante. **Nunca** las ejecutes sobre datos que no quieras perder.
- Para el ejercicio de DLP: una consola de referencia (Microsoft Purview DLP, Forcepoint o el concepto de reglas por patrón, p. ej. expresiones regulares para tarjetas de pago).
- Hoja de cálculo para el cronograma de retención y el registro de destrucción.

🧪 Laboratorio guiado — Diseñar retención, sanitización y un flujo DLP

Continúas con la clínica **"NovaSalud"** de la clase 311.

1. **Cronograma de retención.** Crea una tabla con columnas: `Tipo de dato`, `Base legal`, `Período de retención`, `Acción al vencer`, `Responsable`. Incluye al menos: historia clínica (según ley sanitaria local), datos de tarjeta (PCI DSS: no almacenar el CVV, minimizar PAN), logs de seguridad, correos y nómina.
2. **Árbol de decisión de sanitización.** Diseña un diagrama: dado (medio + nivel de clasificación + destino del medio) → elige Clear, Purge o Destroy usando la tabla de NIST 800-88.
3. **Casos de medio.** Documenta el método correcto para: HDD magnético reutilizado internamente (Clear por sobrescritura), SSD que se dona (Purge por criptoborrado o Secure Erase, **no** sobrescritura simple), y disco con datos `Restringido` que se retira (Destroy físico).
4. **Justifica el SSD.** Explica por qué la sobrescritura de 7 pasadas **no** es fiable en SSD: la capa de traducción flash (FTL) y el over-provisioning dejan bloques inalcanzables.
5. **Certificado de destrucción.** Redacta una plantilla con: identificador del medio, método, fecha, operador, testigo, y firma. Esa es tu evidencia de auditoría.
6. **Flujo DLP en 3 estados.** Define reglas: (a) *reposo* — descubrimiento que localiza PAN sin cifrar en recursos compartidos; (b) *tránsito* — bloqueo de correo saliente con >1 número de tarjeta a dominios externos; (c) *uso/endpoint* — bloqueo de copia de historias clínicas a USB.
7. **Modos de respuesta DLP.** Para cada regla decide: auditar, alertar, cifrar automáticamente o bloquear; y quién recibe el incidente. Evita el exceso de bloqueo que empuja al *shadow IT*.

✍️ Ejercicios

1. Construye un cronograma de retención de 8 tipos de dato con su base legal.
2. Para 5 escenarios (medio + destino + clasificación), indica Clear/Purge/Destroy y la técnica concreta.
3. Explica, con la arquitectura flash, por qué el criptoborrado supera a la sobrescritura en SSD.
4. Diseña 3 reglas DLP (una por estado) con su patrón de detección y su acción.
5. Redacta el procedimiento de retirada de un servidor: desde la baja lógica hasta el certificado.
6. Analiza un incidente: una copia de seguridad en la nube conserva datos que se "borraron" en producción. ¿Qué falló y cómo lo corriges?

📝 Reto verificable

Entrega un **Procedimiento de Retención y Destrucción Segura** que incluya: cronograma de retención con base legal, árbol de decisión de sanitización basado en NIST 800-88, plantilla de certificado de destrucción y tres reglas DLP documentadas (reposo/tránsito/uso).

Criterio de aceptación: dado un lote de 4 medios distintos (HDD interno, SSD donado, cinta de backup, teléfono corporativo) con clasificaciones dadas, tu procedimiento permite a un técnico elegir el método

correcto, ejecutarlo y emitir el certificado sin consultar otra fuente.

⚠️ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Formateé el disco, ya está limpio"	El formateo no elimina datos: hay remanencia. Aplica Clear/Purge/Destroy según NIST 800-88.
Sobrescribir un SSD "7 veces"	La FTL deja bloques fuera de alcance. Usa Secure Erase de firmware o criptoborrado.
Retención "para siempre"	Guardar de más aumenta superficie legal y de fuga. Fija plazos y elimina al vencer.
DLP en modo bloqueo total desde el día 1	Genera falsos positivos y shadow IT. Empieza en modo auditoría y ajusta.
Destruir el medio sin registro	Sin certificado no hay prueba ante auditoría. Emite y archiva el certificado.
Olvidar backups y snapshots	El dato "borrado" sobrevive en réplicas. Incluye copias y nube en el alcance de retención.

❓ Preguntas frecuentes

❓ **¿Cuántas pasadas de sobrescritura necesito en un disco moderno?** En HDD actuales, una sola pasada verificada basta según NIST SP 800-88; el mito de las 7 o 35 pasadas (Gutmann) aplicaba a tecnologías antiguas. En SSD, la sobrescritura no es el método correcto.

❓ **¿Puedo reutilizar el criptoborrado en la nube?** Sí. Si el proveedor cifra por defecto y tú controlas la clave, destruir la clave (crypto-shred) inutiliza el dato. Verifica que no queden copias con otras claves (snapshots antiguos).

❓ **¿DLP reemplaza al cifrado o al control de acceso?** No. DLP es una capa adicional de defensa en profundidad. Complementa —no sustituye— clasificación, cifrado, IAM y formación del usuario.

❓ **¿Retención mínima y máxima pueden coexistir?** Sí, y a veces chocan: una ley exige guardar 5 años, otra (privacidad) exige borrar cuando ya no es necesario. Documenta ambas y define el período que satisface las dos.

> 🔗 **Conexión con la manipulación física de hardware — Parte 17 · Retención y evidencia.** La cadena de custodia de un objeto físico se aplica igual que la de un disco: registro continuo, sellos, estado en cada traspaso y hashes sobre el registro. La clase 268 la aplica a un dispositivo sospechoso y el laboratorio `hardware-tamper-defense` permite practicarla.

🔗 Referencias

- NIST SP 800-88 Rev. 1 — *Guidelines for Media Sanitization*. https://csrc.nist.gov/pubs/sp/800/88/r1/final

- (ISC)² — *CISSP Official Study Guide*, 9.ª ed., Dominio 2 *Asset Security*.
- PCI DSS v4.0 — Requisito 3 (protección de datos de titular de tarjeta almacenados). https://www.pcisecuritystandards.org/
- CompTIA — *Security+ SY0-701 Exam Objectives*, dominio de operaciones de seguridad (data handling).
- ISO/IEC 27040 — *Storage security* (orientación sobre sanitización de almacenamiento).

📥 Material descargable

- 📄 Guía en PDF — versión imprimible de esta clase.
- 🎞️ Presentación (PPTX) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 311 — Clasificación y ciclo de vida de los datos

➡️ Siguiente clase

Clase 313 — Gestión del ciclo de vida de identidades (IAM empresarial)